

(Revision-2021)

Reg.No

Signature.....

MODEL QUESTION PAPER (REV-21)

SIXTH SEMESTER DIPLOMA EXAMINATION IN ENGINEERING/TECHNOLOGY

CYBER SECURITY SET-I

(Maximum Marks : 75)

TIME : 3HRS

PART -A

Answer all questions in one word or one sentence

I.

1. List the triads of computer security.
2. Define encryption.
3. Define Authentication.
4. List any two examples of biometric authentication.
5. Mention the four steps in token based authentication.
6. Define computer viruses
7. List the two approaches for handling intrusion in a computer system.
8. Give two examples of cyber crimes.
9. Mention an information technology law in India.

(9x1=9)

PART B

Answer any eight questions from the following. Each question carries 3 marks.

II.

1. Differentiate confidentiality and integrity.
2. What are the two types of attacks. Explain.
3. Differentiate substitution and transposition.
4. Explain the benefits of hashed passwords.
5. Explain the types of access control.
6. Explain the differences between worms and viruses.
7. List the functionalities of a firewall.
8. Explain the tasks performed by an IDS.
9. Discuss about cyber terrorism.
10. Explain DoS attacks.

(8x3=24)

PART C

Answer all questions from the following. Each question carries 7 marks.

III

1. Explain in detail the components of an information system.

OR

2. Explain the various substitution cipher techniques.

3. Define authentication. Discuss about the various authentication techniques.

OR

4. Briefly explain the two types of access control mechanisms.

5. Discuss about different types of intrusion detection system

OR

6. Explain about the different types of firewalls.

7. Discuss about the intruder behaviour patterns.

OR

8. Explain different classes of intruders.

9. What is meant by ethical hacking. Explain its advantages and limitations.

OR

10. Briefly explain the role of IT act 2000 in addressing cyber crimes.

11. Explain different types of cyber crimes in detail.

OR

12. Explain the measures to be adopted to ensure cyber security.

(6x7=42)

(Revision-2021)

Reg.No

Signature.....

MODEL QUESTION PAPER (REV-21)

SIXTH SEMESTER DIPLOMA EXAMINATION IN ENGINEERING/TECHNOLOGY

CYBER SECURITY SET-II

(Maximum Marks : 75)

TIME : 3HRS

PART -A

Answer all questions in one word or one sentence

I.

1. Define encryption.
2. List the triads of computer security.
3. Define Authentication.
4. List any two examples of biometric authentication.
5. Mention the four steps in token based authentication.
6. List the two approaches for handling intrusion in a computer system.
7. Define computer viruses
8. Mention an information technology law in India.
9. Give two examples of cyber crimes.

(9x1=9)

PART B

Answer any eight questions from the following. Each question carries 3 marks.

II.

1. Differentiate confidentiality and integrity.
2. What are the two types of attacks. Explain.
3. Differentiate substitution and transposition.
4. Explain the benefits of hashed passwords.
5. Explain the types of access control.
6. Explain the differences between worms and viruses.
7. List the functionalities of a firewall.
8. Explain the tasks performed by an IDS.
9. Discuss about cyber terrorism.
10. Explain DoS attacks.

(8x3=24)

PART C

Answer all questions from the following. Each question carries 7 marks.

III

1. Explain in detail the components of an information system.

OR

2. Explain the various substitution cipher techniques.

3. Define authentication. Discuss about the various authentication techniques.

OR

4. Briefly explain the two types of access control mechanisms.

5. Discuss about different types of intrusion detection system

OR

6. Explain about the different types of firewalls.

7. Discuss about the intruder behaviour patterns.

OR

8. Explain different classes of intruders.

9. What is meant by ethical hacking. Explain its advantages and limitations.

OR

10. Briefly explain the role of IT act 2000 in addressing cyber crimes.

11. Explain different types of cyber crimes in detail.

OR

12. Explain the measures to be adopted to ensure cyber security.

(6x7=42)

(Revision-2021)

Reg.No

Signature.....

MODEL QUESTION PAPER (REV-21)

SIXTH SEMESTER DIPLOMA EXAMINATION IN ENGINEERING/TECHNOLOGY

CYBER SECURITY SET-1

(Maximum Marks : 75)

TIME : 3HRS

PART -A

Answer all questions in one word or one sentence

I.

1. Confidentiality, Integrity and availability.
2. The process of converting plaintext to ciphertext is called encryption.
3. The process in which a principal proves that he/she is the entity it claims to be.
4. Finger print scanning, face recognition.
5. Request, verification, token validation and storage.
6. A computer malware that latches on to an executable file and replicate itself.
7. Intrusion detection and prevention.
8. Hacking, phishing
9. IT act 2000

(9x1=9)

PART B

Answer any eight questions from the following. Each question carries 3 marks.

II.

1. Confidentiality is roughly equivalent to privacy. Confidentiality measures are designed to prevent sensitive information from unauthorized access attempts. It is common for data to be categorized according to the amount and type of damage that could be done if it fell into the wrong hands. More or less stringent measures can then be implemented according to those categories.
Integrity involves maintaining the consistency, accuracy and trustworthiness of data over its entire lifecycle. Data must not be changed in transit, and steps must be taken to ensure data cannot be altered by unauthorized people (for example, in a breach of confidentiality).
2. Any three points.

Active Attack	Passive Attack
In an active attack, Modification in information takes place.	While in a passive attack, Modification in the information does not take place.
Active Attack is a danger to Integrity as well as availability.	Passive Attack is a danger to Confidentiality.
In an active attack, attention is on prevention.	While in passive attack attention is on detection.
Due to active attacks, the execution system is always damaged.	While due to passive attack, there is no harm to the system.
In an active attack, Victim gets informed about the attack.	While in a passive attack, Victim does not get informed about the attack.
In an active attack, System resources can be changed.	While in passive attack, System resources are not changing.
Active attack influences the services of the system.	While in a passive attack, information and messages in the system or network are acquired.
In an active attack, information collected through passive attacks is used during execution.	While passive attacks are performed by collecting information such as passwords, and messages by themselves.
An active attack is tough to restrict from entering systems or networks.	Passive Attack is easy to prohibit in comparison to active attack.
Can be easily detected.	Very difficult to detect.
The purpose of an active attack is to harm the ecosystem.	The purpose of a passive attack is to learn about the ecosystem.

Active Attack	Passive Attack
In an active attack, the original information is modified.	In passive attack original information is Unaffected.
The duration of an active attack is short.	The duration of a passive attack is long.
The prevention possibility of active attack is High	The prevention possibility of passive attack is low.
Complexity is High	Complexity is low.

- Both Substitution cipher technique and Transposition cipher technique are the types of Traditional cipher which are used to convert the plain text into cipher text.
Substitution Cipher Technique: In Substitution Cipher Technique plain text characters are replaced with other characters, numbers and symbols as well as in substitution Cipher Technique, character's identity is changed while its position remains unchanged.
Transposition Cipher Technique: Transposition Cipher Technique rearranges the position of the plain text's characters. In transposition Cipher Technique, The position of the character is changed but character's identity is not changed.
- Hashing turns your password (or any other piece of data) into a short string of letters and/or numbers using an encryption algorithm. If a website is hacked, cyber criminals don't get access to your password. Instead, they just get access to the encrypted "hash" created by your password.
- Three main types of access control systems are: Discretionary Access Control (DAC), Role Based Access Control (RBAC), and Mandatory Access Control (MAC).
Discretionary Access Control (DAC) –DAC is a type of access control system that assigns access rights based on rules specified by users.

Role-Based Access Control (RBAC) –RBAC, also known as a non-discretionary access control, is used when system administrators need to assign rights based on organizational roles instead of individual user accounts within an organization.

Mandatory Access Control (MAC) – Considered the strictest of all levels of access control systems. The design and implementation of MAC is commonly used by the government. It uses a hierarchical approach to control access to files/resources. Under a MAC environment, access to resource objects is controlled by the settings defined by a system administrator.

- The primary difference between a virus and a worm is that viruses must be triggered by the activation of their host; whereas worms are stand-alone malicious programs that can self-replicate and propagate independently as soon as they have breached the system. Worms do not

require activation—or any human intervention—to execute or spread their code. Viruses are often attached or concealed in shared or downloaded files, both executable files—a program that runs script—and non-executable files such as a Word document or an image file. When the host file is accepted or loaded by a target system, the virus remains dormant until the infected host file is activated. Only after the host file is activated, can the virus run, executing malicious code and replicating to infect other files on your system. In contrast, worms don't require the activation of their host file. Once a worm has entered your system, usually via a network connection or as a downloaded file, it can then run, self-replicate and propagate without a triggering event. A worm makes multiple copies of itself which then spread across the network or through an internet connection. These copies will infect any inadequately protected computers and servers that connect—via the network or internet—to the originally infected device. Because each subsequent copy of a worm repeats this process of self-replication, execution and propagation, worm-based infections spread rapidly across computer networks and the internet at large.

7. The main functions of a firewall includes:
 - a. Access controll
 - b. Address/port translation
 - c. Logging
 - d. Authentication, caching etc.
8. An Intrusion detection system performs the following tasks:
 - a. It monitors events of interest occuring in the target system or in a network.
 - b. Generates large amount of data which it then analyses and converts into valuable information to be used by system administrator.
 - c. Creates a database of interesting events.
9. Cyberterrorism is the use of the Internet to conduct violent acts that result in, or threaten, the loss of life or significant bodily harm, in order to achieve political or ideological gains through threat or intimidation. Acts of deliberate, large-scale disruption of computer networks, especially of personal computers attached to the Internet by means of tools such as computer viruses, computer worms, phishing, malicious software, hardware methods, programming scripts can all be forms of internet terrorism.
10. A denial-of-service (DoS) attack is a type of cyber attack in which a malicious actor aims to render a computer or other device unavailable to its intended users by interrupting the device's normal functioning. DoS attacks typically function by overwhelming or flooding a targeted machine with requests until normal traffic is unable to be processed, resulting in denial-of-service to addition users. A DoS attack is characterized by using a single computer to launch the attack.

(8x3=24)

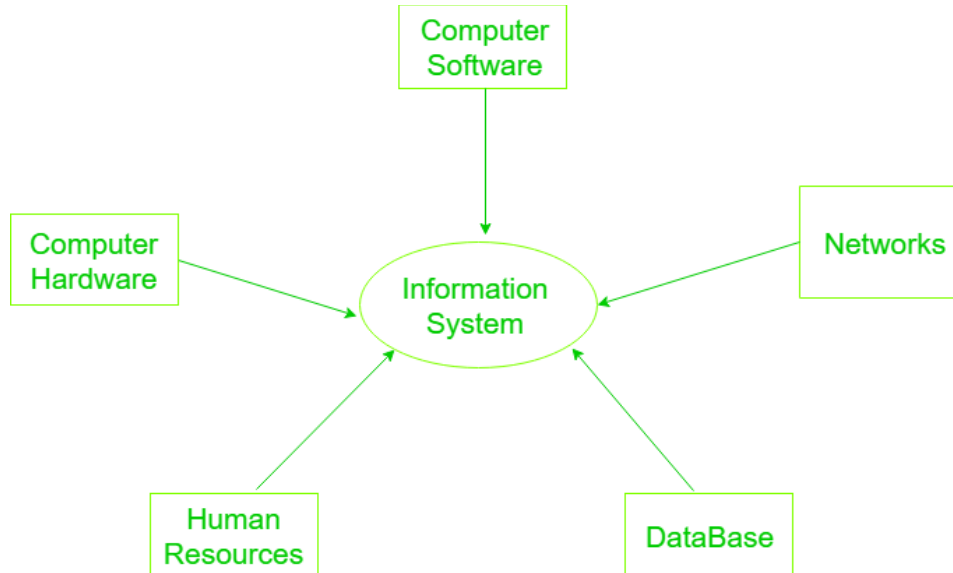
PART C

Answer all questions from the following. Each question carries 7 marks.

III

1. An Information system is a combination of hardware and software and telecommunication networks that people build to collect, create and distribute useful data, typically in an

organization. It defines the flow of information within the system. The objective of an information system is to provide appropriate information to the user, to gather the data, process the data and communicate information to the user of the system.



Components of the information system are as follows:

1. Computer Hardware: Physical equipment used for input, output and processing. The hardware structure depends upon the type and size of the organization. It consists of an input and an output device, operating system, processor, and media devices. This also includes computer peripheral devices.

2. Computer Software: The programs/ application program used to control and coordinate the hardware components. It is used for analysing and processing of the data. These programs include a set of instruction used for processing information.

Software is further classified into 3 types:

System Software

Application Softwares

Procedures

3. Databases: Data are the raw facts and figures that are unorganized that are later processed to generate information. Softwares are used for organizing and serving data to the user, managing physical storage of media and virtual resources. As the hardware can't work without software the same as software needs data for processing. Data are managed using Database management system. Database software is used for efficient access for required data, and to manage knowledge bases.

4. Network: Networks resources refer to the telecommunication networks like the intranet, extranet and the internet. These resources facilitate the flow of information in the organization. Networks consists of both the physical devices such as networks cards, routers, hubs and cables and software such as operating systems, web servers, data servers and application servers. Telecommunications networks consist of computers, communications processors, and other devices interconnected by communications media and controlled by software. Networks include communication media, and Network Support.

5. Human Resources: It is associated with the manpower required to run and manage the system. People are the end user of the information system, end-user use information produced for their own purpose, the main purpose of the information system is to benefit the end user. The end user can be accountants, engineers, salespersons, customers, clerks, or managers etc. People are also responsible to develop and operate information systems. They include systems analysts, computer operators, programmers, and other clerical IS personnel, and managerial techniques.

OR

2. Substitution technique is a classical encryption approach where the characters present in the initial message are restored by the other characters or numbers or by symbols. If the plain text (original message) is treated as the string of bits, thus the substitution technique would restore bit pattern of plain text with the bit pattern of cipher text.

There are various types of substitution ciphers which are as follows –

Monoalphabetic Cipher – In monoalphabetic substitution cipher, a character in a plaintext is always restored or changed to the similar character in the ciphertext indifferent of its position in the text. For instance, if a letter A in the plaintext is changed to G then each appearance of A in the plaintext will be restored by G.

Plaintext : hello

Ciphertext : IFMMP

This is a monoalphabetic cipher as both l's are encrypted as 'M'.

Polyalphabetic cipher – In polyalphabetic substitution, each appearance of a character in the plaintext can have a different substitution character in the ciphertext. The relationship among a character in plaintext and a character in ciphertext is one to many. For instance, letter 'A' can be restored by the letter 'C' and the similar letter 'A' can be restored by 'N' later in the ciphertext. In polyalphabetic cipher, frequencies of plaintext letter are not reflected in the ciphertext. Therefore, breaking of polyalphabetic cipher is complex than monoalphabetic cipher as statistical analysis cannot be used on it. Polyalphabetic substitution cipher is needed a set of associated monoalphabetic substitution rules. It need a key that decides which rule is used for which transformation. It can hiding the letter frequency of the underlying language including Playfair Cipher, Vigenere Cipher, and Hill Cipher.

One-Time Pad – The one-time pad cipher recommend that the key length must be as long as the plain text to avoid the repetition of key. Along with that, the key must be used only once to encrypt and decrypt the individual message after that the key must be discarded.

Caesar Cipher – In this substitution technique, it can encrypt the plain text, each alphabet of the plain text is restored by the alphabet three places further it and it can decrypt the cipher text each alphabet of cipher text is restored by the alphabet three places before it.

Playfair Cipher – The playfair cipher is also known as Playfair Square. It is a cryptographic technique used for manual encryption of information. This scheme was developed by Charles Wheatstone in 1854. The Playfair cipher was used by the British army in World War I and by the Australian in World War II. This was applicable because the playfair cipher is perfectly fast to use and does not demand some specific equipment to be used.

OR

3. Authentication definition – 2 marks, Types of authentication – 5 marks
4. Describe two types of access control mechanisms – each 3.5 marks.

OR

5. Anomaly based, Signature based / Host based, Network based IDS – each 1.75 marks.
6. Packet filters, Stateful inspection firewalls, Application level firewalls. - each 2 marks.

OR

7.

(a) Hacker

1. Select the target using IP lookup tools such as NSLookup, Dig, and others.
2. Map network for accessible services using tools such as NMAP.
3. Identify potentially vulnerable services (in this case, pcAnywhere).
4. Brute force (guess) pcAnywhere password.
5. Install remote administration tool called DameWare.
6. Wait for administrator to log on and capture his password.
7. Use that password to access remainder of network.

(b) Criminal Enterprise

1. Act quickly and precisely to make their activities harder to detect.
2. Exploit perimeter through vulnerable ports.
3. Use Trojan horses (hidden software) to leave back doors for reentry.
4. Use sniffers to capture passwords.
5. Do not stick around until noticed.
6. Make few or no mistakes.

(c) Internal Threat

1. Create network accounts for themselves and their friends.
2. Access accounts and applications they wouldn't normally use for their daily jobs.
3. E-mail former and prospective employers.
4. Conduct furtive instant-messaging chats.
5. Visit Web sites that cater to disgruntled employees, such as fdcompany.com.
6. Perform large downloads and file copying.
7. Access the network during off hours.

OR

8. Classes of intruders -

1. Masquerader: An individual who is not authorized to use the computer and who penetrates a system's access controls to exploit a legitimate user's account.

2. Misfeasor: A legitimate user who accesses data, programs, or resources for which such access is not authorized, or who is authorized for such access but misuses his or her privileges

3. Clandestine user: An individual who seizes supervisory control of the system and uses this control to evade auditing and access controls or to suppress audit collection

9. Ethical hacking definition – 2 marks, Advantages – 3 marks, limitation – 2marks.

10. Role of IT act 2000 – any 7 points – each 1 mark.

11. Types of cyber crimes – any 7 – each 1 mark.

12. Basic measures to ensure cyber safety – Any 7 – each 1 mark.

(Revision-2021)

Reg.No

Signature.....

MODEL QUESTION PAPER (REV-21)

SIXTH SEMESTER DIPLOMA EXAMINATION IN ENGINEERING/TECHNOLOGY

CYBER SECURITY SET-2

(Maximum Marks : 75)

TIME : 3HRS

PART -A

Answer all questions in one word or one sentence

I.

1. The process of converting plaintext to ciphertext is called encryption.
2. Confidentiality, Integrity and availability.
3. The process in which a principal proves that he/she is the entity it claims to be.
4. Finger print scanning, face recognition.
5. Request, verification, token validation and storage.
6. Intrusion detection and prevention.
7. A computer malware that latches on to an executable file and replicate itself.
8. IT act 2000
9. Hacking, phishing

(9x1=9)

PART B

Answer any eight questions from the following. Each question carries 3 marks.

II.

1. Confidentiality is roughly equivalent to privacy. Confidentiality measures are designed to prevent sensitive information from unauthorized access attempts. It is common for data to be categorized according to the amount and type of damage that could be done if it fell into the wrong hands. More or less stringent measures can then be implemented according to those categories.
Integrity involves maintaining the consistency, accuracy and trustworthiness of data over its entire lifecycle. Data must not be changed in transit, and steps must be taken to ensure data cannot be altered by unauthorized people (for example, in a breach of confidentiality).
2. Any three points.

Active Attack	Passive Attack
In an active attack, Modification in information takes place.	While in a passive attack, Modification in the information does not take place.
Active Attack is a danger to Integrity as well as availability.	Passive Attack is a danger to Confidentiality.
In an active attack, attention is on prevention.	While in passive attack attention is on detection.
Due to active attacks, the execution system is always damaged.	While due to passive attack, there is no harm to the system.
In an active attack, Victim gets informed about the attack.	While in a passive attack, Victim does not get informed about the attack.
In an active attack, System resources can be changed.	While in passive attack, System resources are not changing.
Active attack influences the services of the system.	While in a passive attack, information and messages in the system or network are acquired.
In an active attack, information collected through passive attacks is used during execution.	While passive attacks are performed by collecting information such as passwords, and messages by themselves.
An active attack is tough to restrict from entering systems or networks.	Passive Attack is easy to prohibit in comparison to active attack.
Can be easily detected.	Very difficult to detect.
The purpose of an active attack is to harm the ecosystem.	The purpose of a passive attack is to learn about the ecosystem.

Active Attack	Passive Attack
In an active attack, the original information is modified.	In passive attack original information is Unaffected.
The duration of an active attack is short.	The duration of a passive attack is long.
The prevention possibility of active attack is High	The prevention possibility of passive attack is low.
Complexity is High	Complexity is low.

- Both Substitution cipher technique and Transposition cipher technique are the types of Traditional cipher which are used to convert the plain text into cipher text.
Substitution Cipher Technique: In Substitution Cipher Technique plain text characters are replaced with other characters, numbers and symbols as well as in substitution Cipher Technique, character's identity is changed while its position remains unchanged.
Transposition Cipher Technique: Transposition Cipher Technique rearranges the position of the plain text's characters. In transposition Cipher Technique, The position of the character is changed but character's identity is not changed.
- Hashing turns your password (or any other piece of data) into a short string of letters and/or numbers using an encryption algorithm. If a website is hacked, cyber criminals don't get access to your password. Instead, they just get access to the encrypted "hash" created by your password.
- Three main types of access control systems are: Discretionary Access Control (DAC), Role Based Access Control (RBAC), and Mandatory Access Control (MAC).
Discretionary Access Control (DAC) –DAC is a type of access control system that assigns access rights based on rules specified by users.

Role-Based Access Control (RBAC) –RBAC, also known as a non-discretionary access control, is used when system administrators need to assign rights based on organizational roles instead of individual user accounts within an organization.

Mandatory Access Control (MAC) – Considered the strictest of all levels of access control systems. The design and implementation of MAC is commonly used by the government. It uses a hierarchical approach to control access to files/resources. Under a MAC environment, access to resource objects is controlled by the settings defined by a system administrator.

- The primary difference between a virus and a worm is that viruses must be triggered by the activation of their host; whereas worms are stand-alone malicious programs that can self-replicate and propagate independently as soon as they have breached the system. Worms do not

require activation—or any human intervention—to execute or spread their code. Viruses are often attached or concealed in shared or downloaded files, both executable files—a program that runs script—and non-executable files such as a Word document or an image file. When the host file is accepted or loaded by a target system, the virus remains dormant until the infected host file is activated. Only after the host file is activated, can the virus run, executing malicious code and replicating to infect other files on your system. In contrast, worms don't require the activation of their host file. Once a worm has entered your system, usually via a network connection or as a downloaded file, it can then run, self-replicate and propagate without a triggering event. A worm makes multiple copies of itself which then spread across the network or through an internet connection. These copies will infect any inadequately protected computers and servers that connect—via the network or internet—to the originally infected device. Because each subsequent copy of a worm repeats this process of self-replication, execution and propagation, worm-based infections spread rapidly across computer networks and the internet at large.

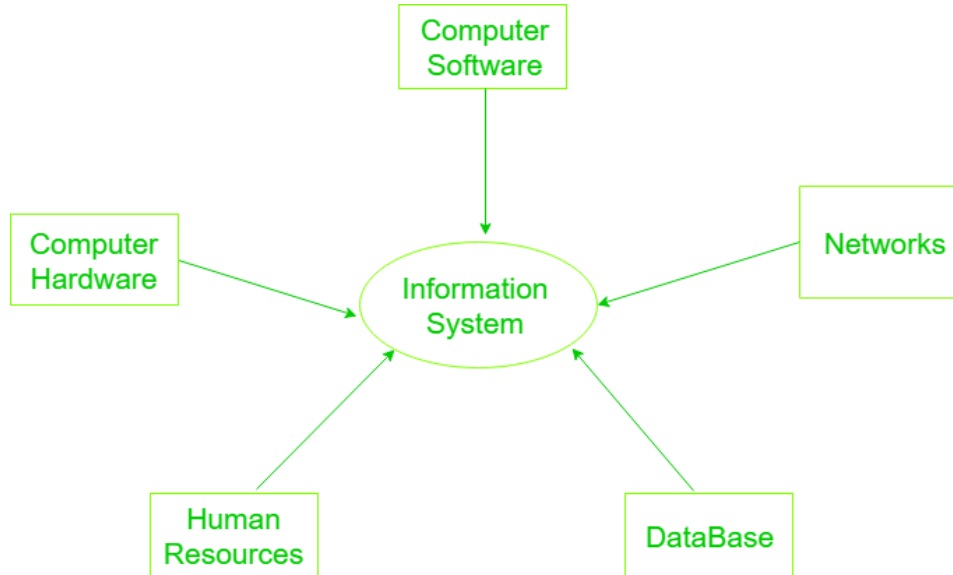
7. The main functions of a firewall includes:
 - a. Access controll
 - b. Address/port translation
 - c. Logging
 - d. Authentication, caching etc.
8. An Intrusion detection system performs the following tasks:
 - a. It monitors events of interest occuring in the target system or in a network.
 - b. Generates large amount of data which it then analyses and converts into valuable information to be used by system administrator.
 - c. Creates a database of interesting events.
9. Cyberterrorism is the use of the Internet to conduct violent acts that result in, or threaten, the loss of life or significant bodily harm, in order to achieve political or ideological gains through threat or intimidation. Acts of deliberate, large-scale disruption of computer networks, especially of personal computers attached to the Internet by means of tools such as computer viruses, computer worms, phishing, malicious software, hardware methods, programming scripts can all be forms of internet terrorism.
10. A denial-of-service (DoS) attack is a type of cyber attack in which a malicious actor aims to render a computer or other device unavailable to its intended users by interrupting the device's normal functioning. DoS attacks typically function by overwhelming or flooding a targeted machine with requests until normal traffic is unable to be processed, resulting in denial-of-service to addition users. A DoS attack is characterized by using a single computer to launch the attack.

$$(8 \times 3 = 24)$$

PART C

Answer all questions from the following. Each question carries 7 marks.

1. An Information system is a combination of hardware and software and telecommunication networks that people build to collect, create and distribute useful data, typically in an organization. It defines the flow of information within the system. The objective of an information system is to provide appropriate information to the user, to gather the data, process the data and communicate information to the user of the system.



Components of the information system are as follows:

1. **Computer Hardware:** Physical equipment used for input, output and processing. The hardware structure depends upon the type and size of the organization. It consists of an input and an output device, operating system, processor, and media devices. This also includes computer peripheral devices.

2. **Computer Software:** The programs/ application program used to control and coordinate the hardware components. It is used for analysing and processing of the data. These programs include a set of instruction used for processing information.

Software is further classified into 3 types:

- System Software
- Application Softwares
- Procedures

3. **Databases:** Data are the raw facts and figures that are unorganized that are later processed to generate information. Softwares are used for organizing and serving data to the user, managing physical storage of media and virtual resources. As the hardware can't work without software the same as software needs data for processing. Data are managed using Database management system. Database software is used for efficient access for required data, and to manage knowledge bases.

4. **Network:** Networks resources refer to the telecommunication networks like the intranet, extranet and the internet. These resources facilitate the flow of information in the organization. Networks consists of both the physical devices such as networks cards, routers, hubs and cables and software such as operating systems, web servers, data servers and application servers. Telecommunications networks consist of computers, communications processors, and other devices interconnected by

communications media and controlled by software. Networks include communication media, and Network Support.

5. Human Resources: It is associated with the manpower required to run and manage the system. People are the end user of the information system, end-user use information produced for their own purpose, the main purpose of the information system is to benefit the end user. The end user can be accountants, engineers, salespersons, customers, clerks, or managers etc. People are also responsible to develop and operate information systems. They include systems analysts, computer operators, programmers, and other clerical IS personnel, and managerial techniques.

OR

2. Substitution technique is a classical encryption approach where the characters present in the initial message are restored by the other characters or numbers or by symbols. If the plain text (original message) is treated as the string of bits, thus the substitution technique would restore bit pattern of plain text with the bit pattern of cipher text.

There are various types of substitution ciphers which are as follows –

Monoalphabetic Cipher – In monoalphabetic substitution cipher, a character in a plaintext is always restored or changed to the similar character in the ciphertext indifferent of its position in the text. For instance, if a letter A in the plaintext is changed to G then each appearance of A in the plaintext will be restored by G.

Plaintext : hello

Ciphertext : IFMMP

This is a monoalphabetic cipher as both l's are encrypted as 'M'.

Polyalphabetic cipher – In polyalphabetic substitution, each appearance of a character in the plaintext can have a different substitution character in the ciphertext. The relationship among a character in plaintext and a character in ciphertext is one to many. For instance, letter 'A' can be restored by the letter 'C' and the similar letter 'A' can be restored by 'N' later in the ciphertext. In polyalphabetic cipher, frequencies of plaintext letter are not reflected in the ciphertext. Therefore, breaking of polyalphabetic cipher is complex than monoalphabetic cipher as statistical analysis cannot be used on it. Polyalphabetic substitution cipher is needed a set of associated monoalphabetic substitution rules. It need a key that decides which rule is used for which transformation. It can hiding the letter frequency of the underlying language including Playfair Cipher, Vigenere Cipher, and Hill Cipher.

One-Time Pad – The one-time pad cipher recommend that the key length must be as long as the plain text to avoid the repetition of key. Along with that, the key must be used only once to encrypt and decrypt the individual message after that the key must be discarded.

Caesar Cipher – In this substitution technique, it can encrypt the plain text, each alphabet of the plain text is restored by the alphabet three places further it and it can decrypt the cipher text each alphabet of cipher text is restored by the alphabet three places before it.

Playfair Cipher – The playfair cipher is also known as Playfair Square. It is a cryptographic technique used for manual encryption of information. This scheme was developed by Charles Wheatstone in 1854. The Playfair cipher was used by the British army in World War I and by the Australian in World War II. This was applicable because the playfair cipher is perfectly fast to use and does not demand some specific equipment to be used.

OR

3. Authentication definition – 2 marks, Types of authentication – 5 marks
4. Describe two types of access control mechanisms – each 3.5 marks.

OR

5. Anomaly based, Signature based / Host based, Network based IDS – each 1.75 marks.
6. Packet filters, Stateful inspection firewalls, Application level firewalls. - each 2 marks.

OR

7.

(a) Hacker

1. Select the target using IP lookup tools such as NSLookup, Dig, and others.
2. Map network for accessible services using tools such as NMAP.
3. Identify potentially vulnerable services (in this case, pcAnywhere).
4. Brute force (guess) pcAnywhere password.
5. Install remote administration tool called DameWare.
6. Wait for administrator to log on and capture his password.
7. Use that password to access remainder of network.

(b) Criminal Enterprise

1. Act quickly and precisely to make their activities harder to detect.
2. Exploit perimeter through vulnerable ports.
3. Use Trojan horses (hidden software) to leave back doors for reentry.
4. Use sniffers to capture passwords.
5. Do not stick around until noticed.
6. Make few or no mistakes.

(c) Internal Threat

1. Create network accounts for themselves and their friends.
2. Access accounts and applications they wouldn't normally use for their daily jobs.
3. E-mail former and prospective employers.
4. Conduct furtive instant-messaging chats.
5. Visit Web sites that cater to disgruntled employees, such as fdcompany.com.
6. Perform large downloads and file copying.
7. Access the network during off hours.

OR

8. Classes of intruders -

1. Masquerader: An individual who is not authorized to use the computer and who penetrates a system's access controls to exploit a legitimate user's account.

2. Misfeasor: A legitimate user who accesses data, programs, or resources for which such access is not authorized, or who is authorized for such access but misuses his or her privileges

3. Clandestine user: An individual who seizes supervisory control of the system and uses this control to evade auditing and access controls or to suppress audit collection

9. Ethical hacking definition - 2 marks, Advantages - 3 marks, limitation - 2marks.

10. Role of IT act 2000 - any 7 points - each 1 mark.

11. Types of cyber crimes - any 7 - each 1 mark.

12. Basic measures to ensure cyber safety - Any 7 - each 1 mark.